Support

Pentest the Support Ops platform to exploit vulnerabilities and achieve RCE.

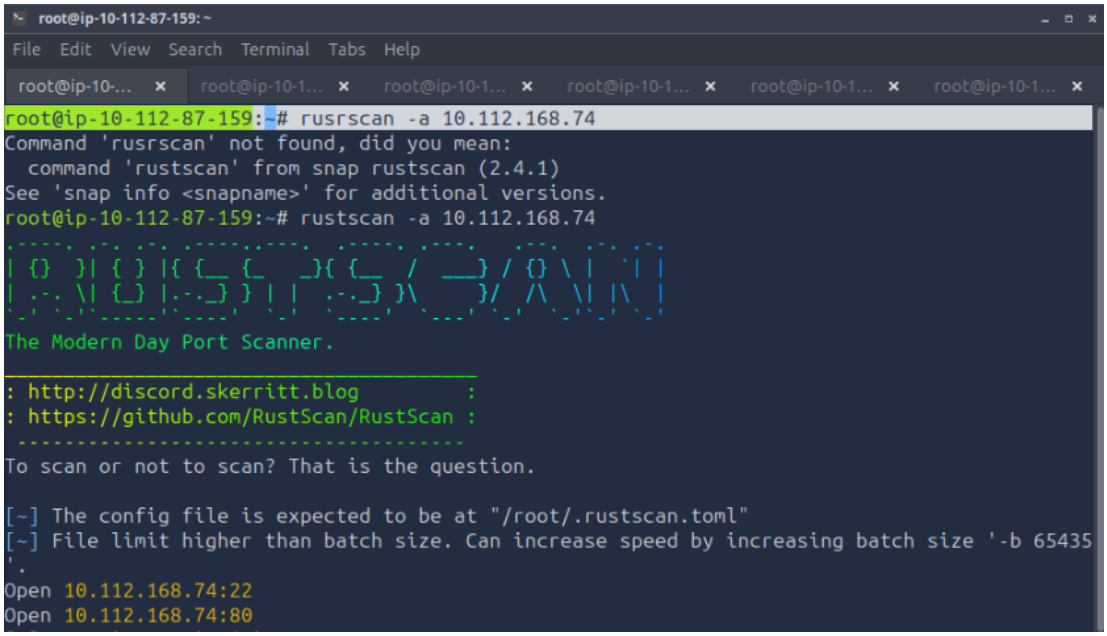
A new internal Support Operations Platform has been deployed to assist IT and helpdesk teams. The application handles user management, internal APIs, and system-level operations. However, security was not the primary focus during development. Several features rely on user-controlled input and weak trust boundaries.

RCE - Remote Code Execution (RCE) is a vulnerability that allows an attacker to run arbitrary code on a remote system. If exploited successfully, it often leads to full system compromise.

Can you pentest the platform and escalate your access to achieve RCE on the server?

Started with rustscan in order to get open port

root@ip-10-112-87-159:~# rusrscan -a 10.112.168.74



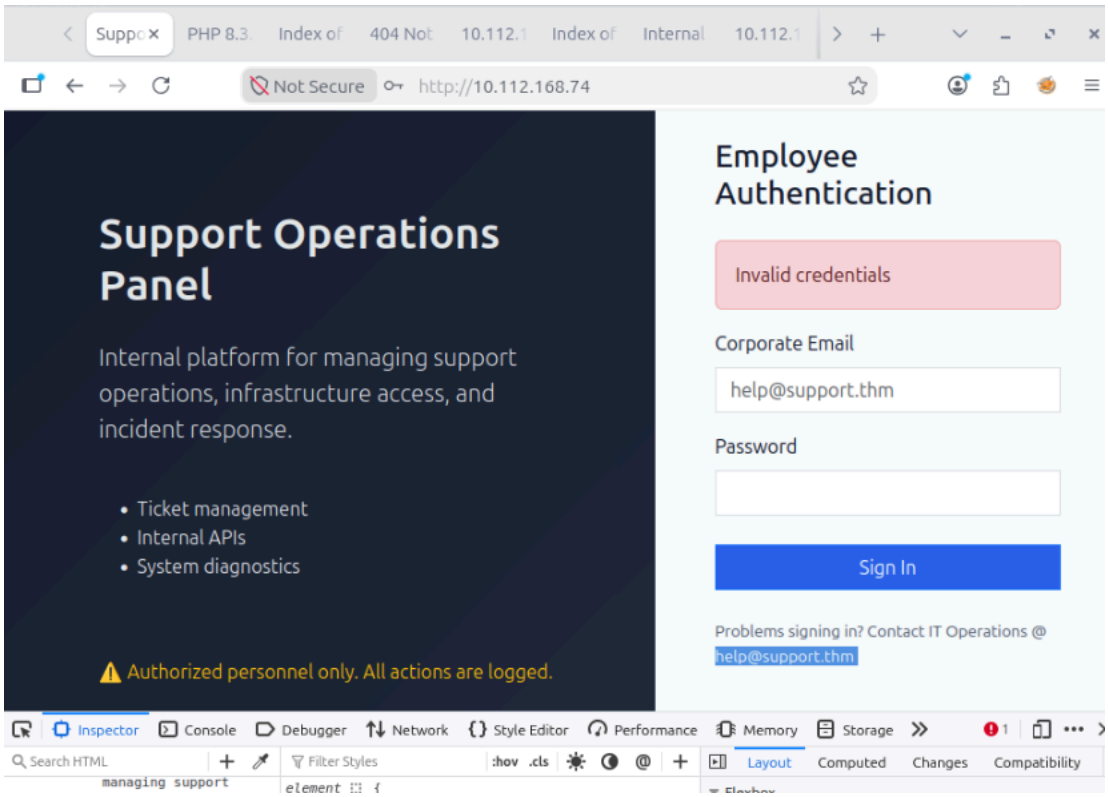
Then applied with gobuster in order to get diroctory

1. My first thought is to run Gobuster to find hidden directories and files, since I don't yet have a password. The directories and files Gobuster discovers may very well be entry points.

root@ip-10-112-87-159:~# gobuster dir -u http://10.112.168.74 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,bak.zip.js

```
root@ip-10-112-87-159:~# gobuster dir -u http://10.112.168.74 -w /usr/share/wordlists/dirbus
ter/directory-list-2.3-medium.txt -x php,txt,bak.zip.js
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.112.168.74
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,txt,bak.zip.js
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.php                (Status: 403) [Size: 278]
/index.php           (Status: 200) [Size: 2591]
/info.php            (Status: 200) [Size: 73303]
/footer.php          (Status: 200) [Size: 1253]
/skins               (Status: 301) [Size: 314]
/includes            (Status: 301) [Size: 317]
/layout              (Status: 301) [Size: 315]
/js                  (Status: 301) [Size: 311]
/api.php             (Status: 302) [Size: 0]
/logout.php          (Status: 302) [Size: 0]
/config.php          (Status: 200) [Size: 0]
/dashboard.php       (Status: 302) [Size: 0]
/server-status       (Status: 403) [Size: 278]
Progress: 873100 / 873104 (100.00%)
```

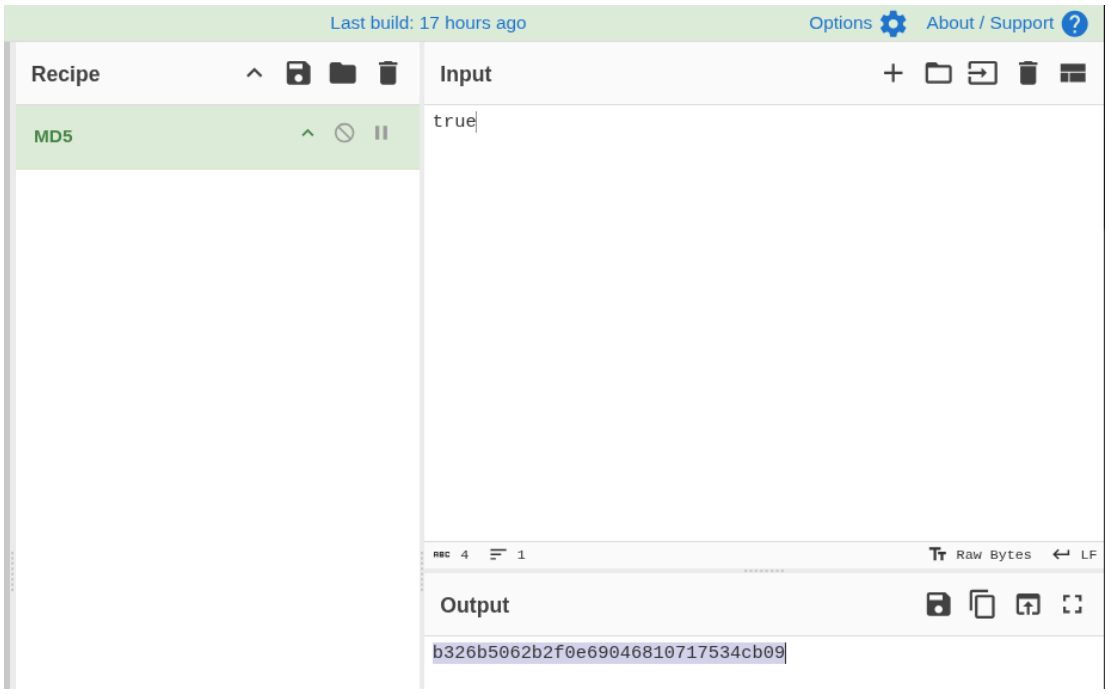
Inserted ragel password go to inpest

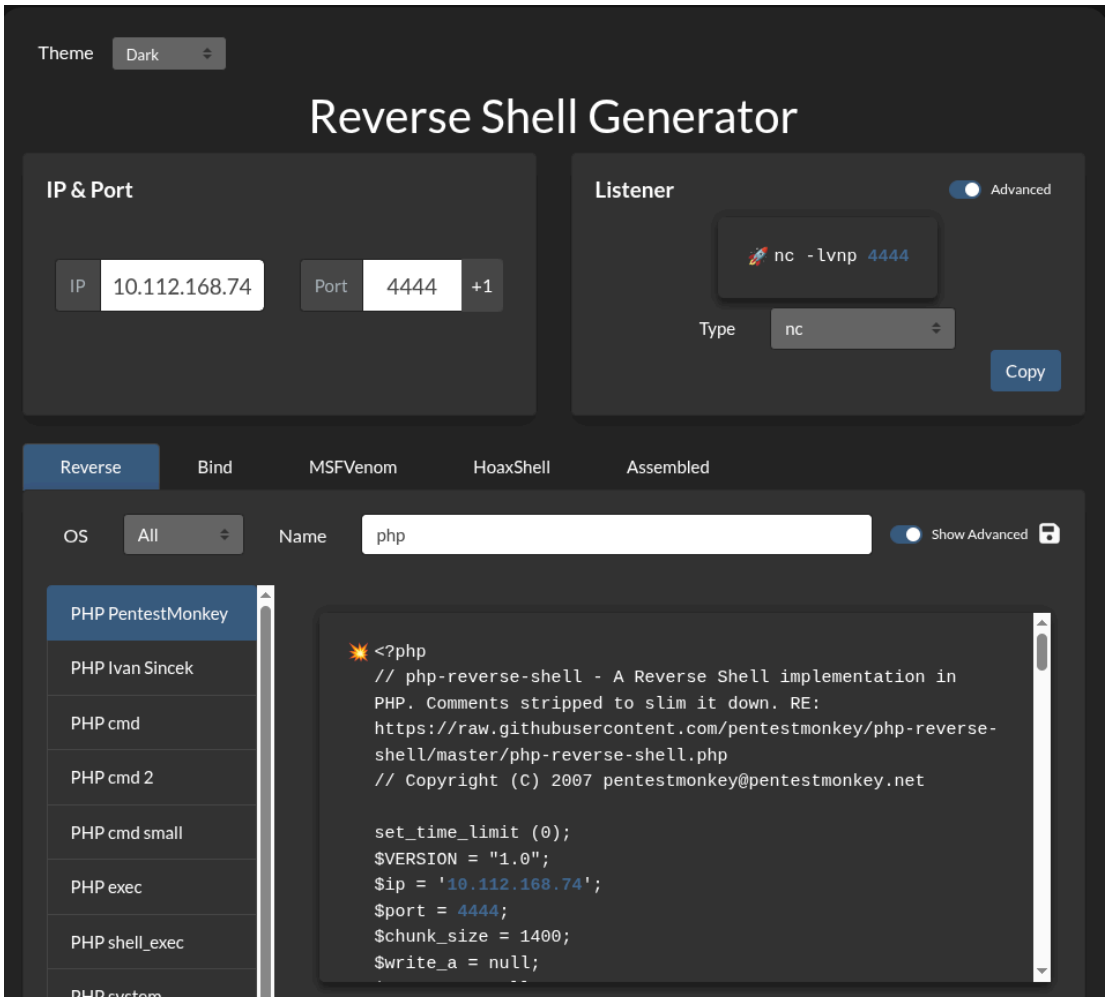


Answer the questions below

> What is the flag value after logging in as admin?

THM{I_AM_ADMIN999}


Last build: 17 hours ago
Options
About / Support
Recipe
MD5
Input
true
4
1
Raw Bytes
LF
Output
b326b5062b2f0e69046810717534cb09



> What is the content of the file /home/ubuntu/user.txt?

THM{GOT_THE_FLAG001}